

Service Availability & Commitments Policy

Version: v1.0 ADOPTED **Adopted:** 2026-07-21 by Sami Ben Chaalia (Security Officer) **Date:** 2026-07-21 **Owner:** Security Officer (Sami Ben Chaalia) **Framework mapping:** SOC 2 A1.1 (Availability commitments met) · A1.2 (Environmental protections + recovery) · A1.3 (Recovery + change management support availability) **Companion documents:** BC/DR Policy · Incident Response Policy · Vendor Management Policy · railcall.ai/legal/terms (customer-facing companion).

1. Purpose

State what customers can actually expect from RailCall in terms of uptime, degradation, and communication — and what happens when we miss. Written to match reality, not aspiration. Enterprise buyers ask for an SLA; this is the operator-internal version that backs the customer-facing SLA in the Terms of Service.

2. Service classes

RailCall has three service classes with different availability expectations because they have different customer impact profiles.

2.1 Local station (customer's own machine)

- **Availability commitment:** N/A — runs on the customer's box; our uptime doesn't affect it.
- **What we owe:** the station tarball at `railcall.ai/railcall\_station.tar.gz` must be reachable + integrity-verified, so customers can reinstall + get updates.
- **Customer expectation:** if their box is up, the station is up.

2.2 Public installer + tarball mirror (`railcall.ai/install.sh` + `/railcall\_station.tar.gz`)

- **Availability commitment: 99.5% monthly** — roughly 3.5 hours of allowed downtime per month.
- **What we owe:** the URL responds with the pinned installer or tarball, byte-identical to the GitHub Release copy.
- **Recovery target (RTO): 4 hours** per BC/DR §5.4.
- **Failure mode:** existing customers unaffected; new installs blocked. Communicate via Discord + Twitter.

2.3 Gateway (railcall-core.onrender.com — paid tier only)

- **Availability commitment: 99.5% monthly** for the paid-tier endpoints (`/v1/entitlement/mint`, `/v1/seat/checkin`, `/v1/attestation/countersign`, `/create-seat-checkout-session`, `/v1/webhooks/stripe`).
- **What we owe:** endpoints respond within 2 seconds under normal load; return honest failure codes (503 for our-side, 5xx from Render for their-side, per §4).
- **Recovery target (RTO): 4 hours** per BC/DR §5.2.
- **Failure mode:** paid customers with existing entitlements are unaffected (verification is local); new mints, new checkins, new checkouts blocked until recovery.
- **Data loss target (RPO): 24 hours** on managed Postgres backup surface.

Free-tier local runtime is not subject to gateway availability because it doesn't depend on the gateway.

3. Measurement + reporting

- **Availability = 100% × (total minutes in period – unplanned downtime minutes) / total minutes.**
- **Planned maintenance** (with ≥ 48 h advance notice) is excluded from downtime.
- **Third-party outages upstream of us** (Render, DO, Cloudflare, Stripe) count toward our downtime — we own the customer relationship, we own the impact.
- **Measurement source:** Render's own service metrics for the gateway; external synthetic monitoring for the mirror (TO BE ADDED — currently monitored ad-hoc via `curl`).

Monthly summary posted internally in incident notes; customer-visible status page is a future item.

4. Failure semantics — how errors are communicated

Consistent HTTP codes matter more than a specific uptime number, because a customer that gets an honest 503 knows to retry, while a customer that gets a masked 200-with-bad-data cannot.

- **4xx:** the customer's request is wrong. 400 malformed, 401 unknown key, 402 payment/capacity, 403 not entitled, 404 not found.
- **503:** service correctly detected an unrecoverable-right-now state (e.g., issuer seed unset, licensing authority unavailable). Retry-safe.
- **5xx (other):** genuine internal error — logged, alerted, treated as an incident per Incident Response Policy §3.

- **Never:** 200 with a fake success payload, empty result silently in place of an error, or silently degraded functionality.

5. Degraded service

Rather than full outages, we optimize for graceful degradation:

- **Free-tier local engine keeps working** when the gateway is down. This is architectural — the engine has no runtime dependency on the gateway.
- **Existing paid entitlements keep working** when the gateway is down. Entitlements are locally-verified against a pinned public key; they only need the gateway for MINTING new ones.
- **Seat checkin fails-open** briefly: an install that can't reach `/v1/seat/checkin` continues with its most recent successful checkin's TTL (30 days per Data Retention §3), not immediately kicked.
- **Webhook retries** are Stripe's job — a temporarily-down `/v1/webhooks/stripe` gets retried by Stripe for 72 hours per their defaults.

6. Planned maintenance

- **Announce ≥ 48 hours in advance** via email to paying customers + Discord post + banner on railcall.ai.
- **Prefer maintenance windows** during low-traffic periods (weekend nights UTC).
- **Zero-downtime deploys preferred:** Render's blue-green pattern for gateway; VPS website `pm2 restart` is ~2 seconds and usually mid-day is fine.
- **Rolling back a bad deploy** doesn't count as planned maintenance (it's an incident recovery per Change Management §7).

7. Communication during incidents

Cross-references Incident Response Policy §8:

- **Any incident affecting the gateway:** post to Discord within 30 min of confirmation, update every hour.
- **Any incident affecting a specific customer:** direct email from `security@railcall.ai`.
- **Post-mortem for any SEV-1 or SEV-2:** shared with affected customers within 5 business days per Incident Response §9.

8. Compensation for SLA breach

Not offered today by default. If a paying customer has an incident-affected month:

- **Sami reviews on request** and typically extends the subscription by the affected days as goodwill. Not automated.
- **Enterprise contracts** may include a formal SLA credit schedule negotiated per-customer.

Explicit non-goal: no financial guarantees baked into the standard `railcall.ai/legal/terms` — the paid tier is a monthly subscription at \$20/seat, sub-guarantee levels appropriate for that price point.

9. Third-party dependency availability

Our availability is bounded by our upstream. See Vendor Management Policy §3 for per-vendor posture. Specifically:

- **Render's SLA:** their published number bounds our gateway availability.
- **DigitalOcean's SLA:** their published number bounds our VPS availability.
- **Cloudflare's SLA:** their published number bounds `railcall.ai` DNS resolution + edge.
- **Stripe's SLA:** their published number bounds new-signup + subscription-lifecycle event availability.

Publishing our own SLA higher than the min of these would be dishonest — the number in §2 respects that.

10. Capacity planning

At current scale (single-digit paying customers, sub-100 free users), capacity is not a limiting factor on any surface. Reviewed quarterly:

- **Gateway response times:** if p99 exceeds 500 ms sustained → investigate (either code, DB indexes, or Render tier upgrade).
- **Postgres row counts:** `consumers`, `seat_reservations`, `processed_events` — projection reviewed quarterly against Render's plan capacity.
- **VPS resources:** `htop` + `df` review during quarterly access review; upgrade droplet size proactively rather than on-demand.

Scaling triggers documented in `~/reviews/YYYY-QN-capacity-review.md`.

11. Review

At each station release + at least annually. Availability numbers in §2 revisited annually against actual measurement — if we consistently beat them, raise the commitment (customers get the honest number); if we consistently miss, lower and investigate why.

12. Related documents

- **BC/DR Policy §3** — RTO/RPO targets this policy commits to publicly.
- **Incident Response Policy §3, §8** — the severity classification + notification mechanics this policy points customers at.
- **Vendor Management Policy §3** — the upstream SLAs bounding our commitment.
- **Change Management Policy §7** — the rollback path that supports the §6 planned-maintenance approach.
- **railcall.ai/legal/terms** — the customer-facing legal version of §2 + §8.